

# Vulnerability Assessment Report

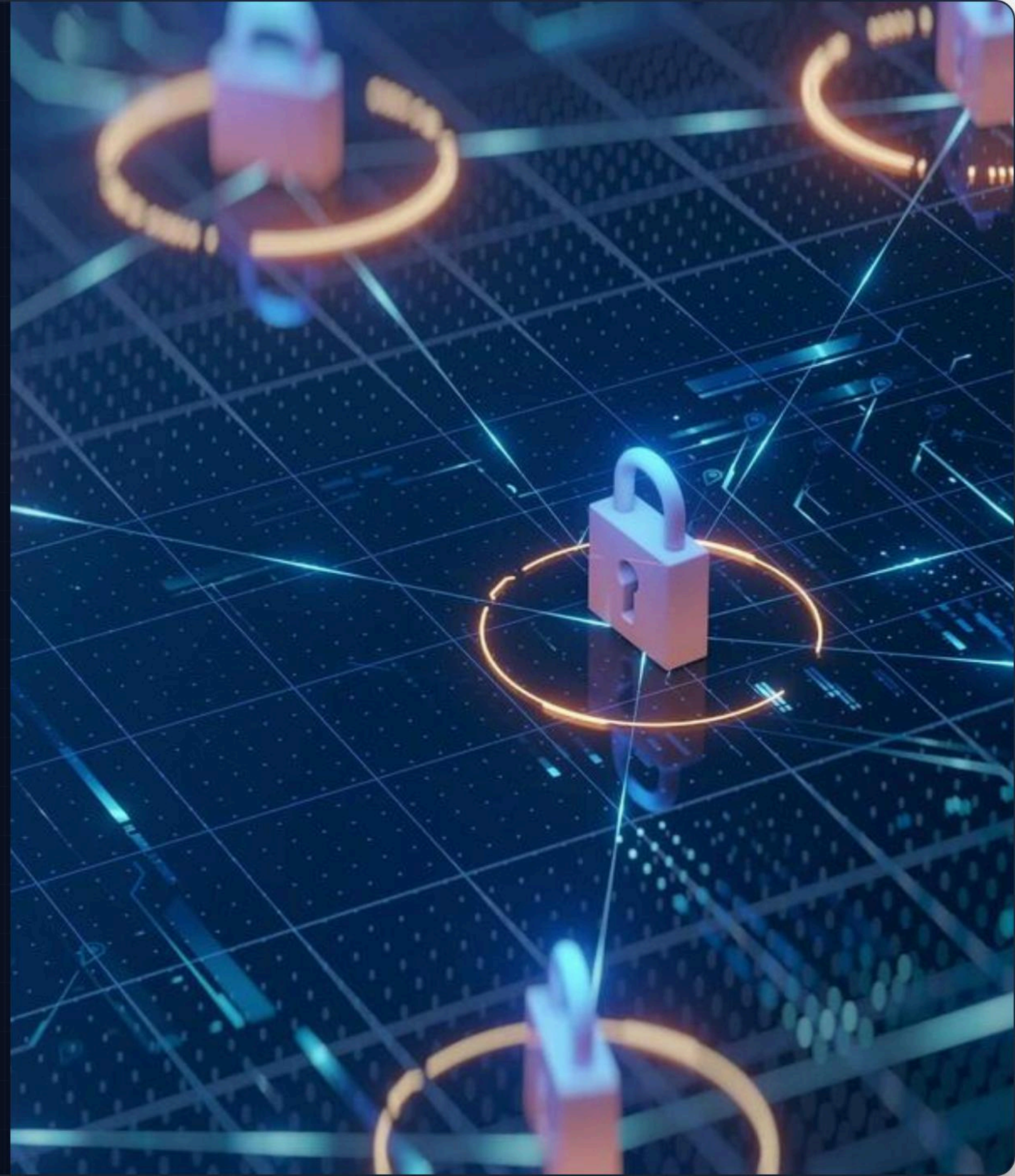
Future Interns – Cyber Security Task 1

🌐 **Website Tested:** demo.testfire.net

Prepared By: **Gokul**

Department: **B.Tech AIML – SNS College**

Date: **09 May 2026**





# Executive Summary

## Introduction

---

A comprehensive **passive vulnerability assessment** was conducted on the designated public web application.

The assessment utilized ethical and read-only testing techniques to ensure zero disruption to the active services while identifying potential security misconfigurations.

## Primary Objectives

---

- Identify common web security weaknesses without active exploitation.
- Analyze HTTP security headers for proper configuration.
- Inspect session cookies for secure transmission flags.
- Classify identified risks based on industry standards.
- Suggest actionable remediation methods and prepare a professional report.



# Assessment Scope & Toolkit



## Included

- Passive scanning
- Header analysis
- Cookie inspection
- Information gathering



## Excluded

- Active Exploitation
- Brute-force attacks
- Denial of Service (DoS)
- Social Engineering



## Tools Used

- **OWASP ZAP:** Proxy interception
- **Browser DevTools:** Header inspection
- **Nmap:** Port scanning

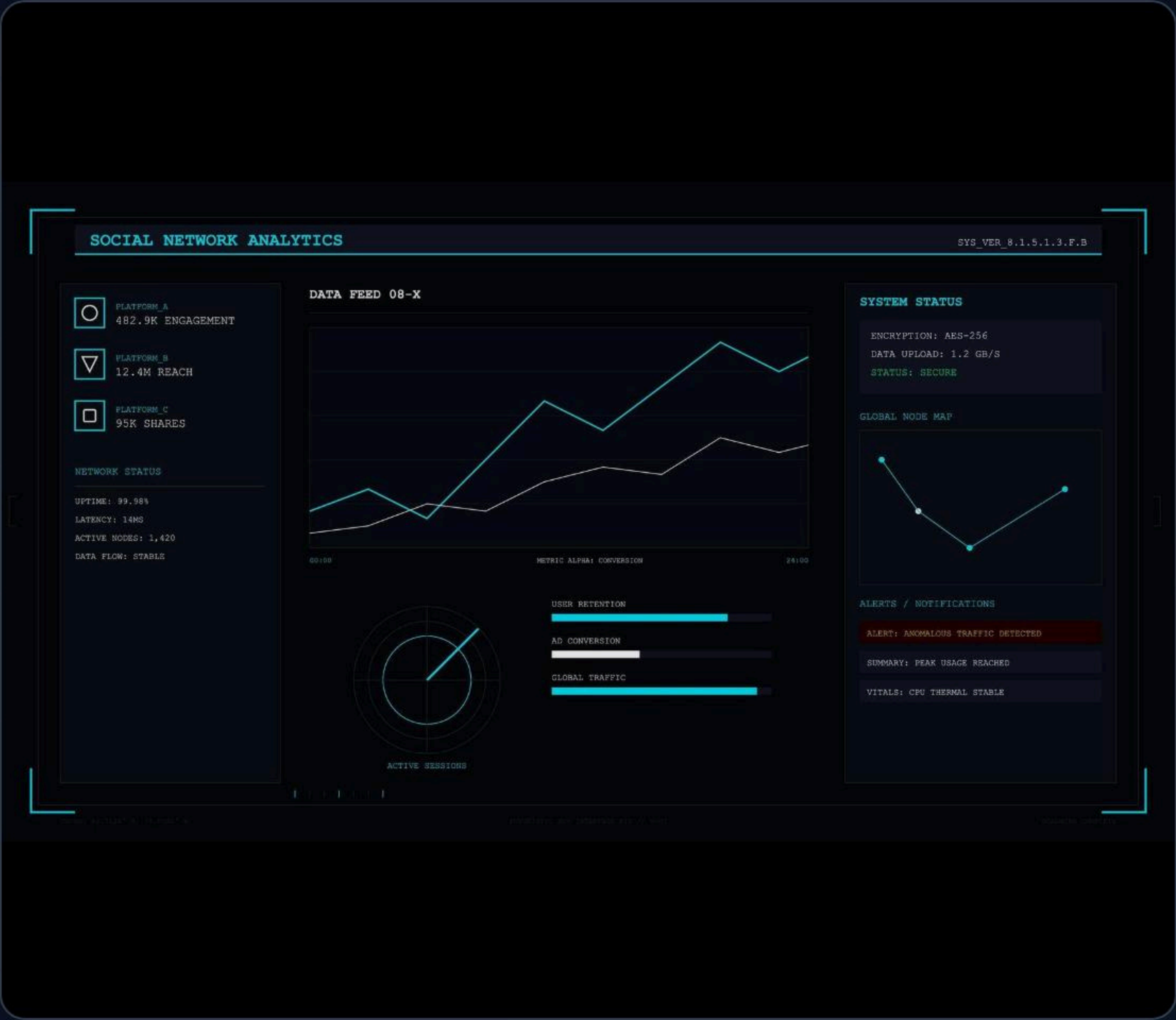


# Findings Summary Overview

| RISK LEVEL            | COUNT |
|-----------------------|-------|
| ● Medium              | 2     |
| ● Low                 | 3     |
| ● Informational       | 1     |
| Total Vulnerabilities | 6     |

## Identified Issues:

- > CSP Header Not Set (Medium)
- > Missing Anti-clickjacking Header (Medium)
- > Cookie without SameSite (Low)
- > Server Information Disclosure (Low)
- > X-Content-Type-Options Missing (Low)





# Medium Risk Vulnerabilities

## 1. CSP Header Not Set

**Impact:** No Content Security Policy implemented. This significantly increases the risk of Cross-Site Scripting (XSS) attacks by allowing unauthorized asset execution.

🔧 Implement robust CSP headers

## 2. Missing Anti-clickjacking Header

**Impact:** The website lacks structural frame protection. This omission may allow clickjacking attacks where a malicious site embeds the target in an invisible iframe.

🔧 Add: X-Frame-Options: DENY



# Low Risk Vulnerabilities

## 1. Cookie without SameSite

Session cookie lacks SameSite protection, potentially increasing Cross-Site Request Forgery (CSRF) risks across domains.

## 2. Server Version Disclosure

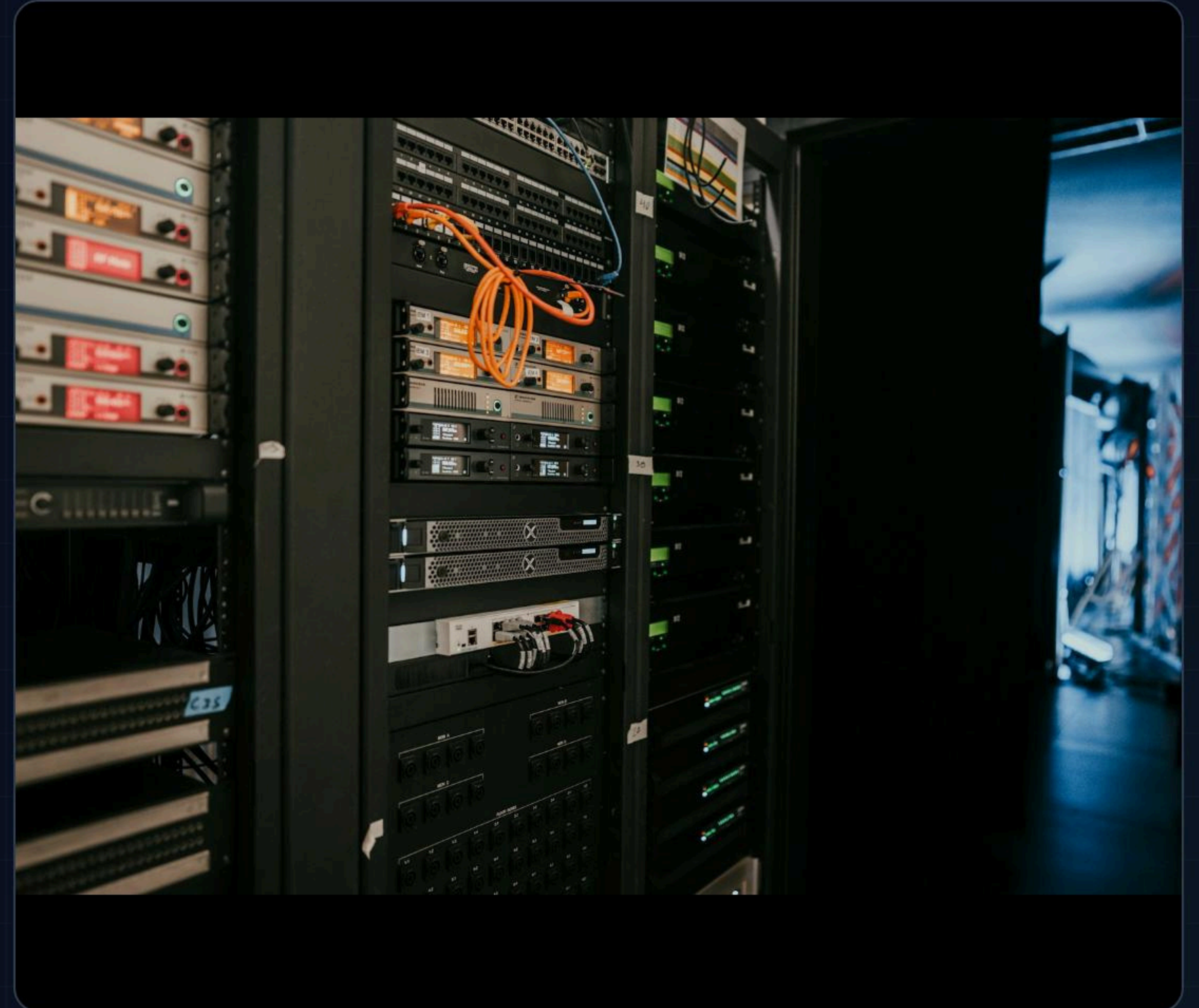
Server technology details are publicly exposed in the headers. This reconnaissance data helps attackers tailor specific exploits.

## 3. X-Content-Type-Options Missing

MIME-sniffing protection is absent, which can lead to content confusion attacks by forcing the browser to misinterpret files.

### General Recommendations

Enforce SameSite cookie attributes, mask server version strings, and deploy comprehensive HTTP security headers.





# Conclusion

The assessment successfully identified several common web security misconfigurations through passive testing techniques.

Although no critical, exploitable vulnerabilities were discovered during this phase, proactively implementing the recommended security header improvements will greatly strengthen the overall defensive posture of the web application.

THANK YOU